CO1 - Security Features in Real-World Applications

1. Security Features in Real-World Applications

Security is essential in real-world applications because users exchange sensitive information, authenticate their identities, and perform financial or other transactions. The major security objectives include Confidentiality, Integrity, Authentication, Authorization, and Availability (CIA + AAA).

Application	Security Feature	Security Mechanism	Protocol / Technology	How it provides security
Gmail	Authentication	Password + Multi-Factor Authentication (MFA)	OAuth 2.0, OpenID Connect, TOTP / Security Keys	Ensures that the user logs in to the account with a password and another type of authentication, so that unauthorized access to the account is prevented.
Online Banking	Confidentiality	Encryption	HTTPS / TLS	Provides security when the user's device communicates with the banking server, so that the attacker is unable to read the information such as account numbers and passwords.
WhatsApp	Confidentiality	End-to-End Encryption	Signal Protocol	Encrypts messages on the sending device and decodes the messages only on the receiving device, so that no one else can read them.
Amazon / E-commerce	Integrity	Digital signatures and secure transaction mechanisms	HTTPS / TLS, Digital Signatures	Ensures that information that is sent during a transaction is not altered during transmission and helps assure that data received by the server

				is equal to data sent by the customer.
Google Drive / Cloud Storage	Authorization	Access Control	OAuth 2.0, IAM, Access Control Lists (ACLs)	Sets the permissions to control access to files and what operations can be performed on those files, such as viewing, editing, or sharing.

Explanation of the Applications

1. Gmail - Authentication

Gmail employs security measures like passwords and Multi-Factor Authentication (MFA). Secure authorisation and identity flows are supported using technologies like OAuth 2.0 and OpenID Connect. MFA added to this layer of protection as if the attacker gains the password, he can't access the account without the second factor.

2. Online Banking - Confidentiality

Online banking is secured by the use of HTTPS with TLS for transactions between the customer's device and the bank's server. TLS is used to encrypt the communications link, which means that the credentials and account details or transaction information are not easily readable by attackers breaching the communications path.

3. WhatsApp - Confidentiality

Signal Protocol is used for end-to-end encryption in WhatsApp. Sending of a message to the recipient is encrypted by the sender's device and decrypted by the recipient's device. This safeguards the contents of the messages, even if the messages flow through WhatsApp's network.

4. Amazon - Integrity

E-commerce websites rely on TLS to ensure secure communications and cryptographic systems to secure transactions. TLS can be used to provide integrity protection for any data being sent in the flow of traffic as it passes through the connection, which can help to prevent a hostile party from tampering with the data going through the connection without any harm being noticed.

5. Google Drive - Authorization

Cloud storage services apply access control methods to decide which users have access to files via cloud services and which permissions are granted to them. Users can be granted access to edit, download, view and share a resource through access control, and delegated authorization can be employed with OAuth 2.0.

2. Security Controls in Real-World Applications

Security controls can be classified according to the security property they primarily protect: Confidentiality (C), Integrity (I), and Availability (A). They can also be classified according to their role in the attack lifecycle: Preventive, Detective, and Recovery controls.

Application	CIA Property	Security Control	Mechanism	Protocol / Technology	Control Type	How it Helps
Gmail	Confidentiality	Encryption	Encryption of data in transit and at rest	TLS, AES	Preventive	Prevents attackers from reading emails and stored data without authorization.
Gmail	Integrity	Email authentication	Sender/domain authentication	SPF, DKIM, DMARC	Preventive / Detective	Helps prevent spoofed emails and detects unauthorized use of a domain.
Gmail	Availability	Backup and service redundancy	Replication and redundant infrastructure	Cloud infrastructure	Recovery / Preventive	Helps maintain access to email services despite hardware failures or attacks.
Online Banking	Confidentiality	Secure communication	Encryption	HTTPS / TLS	Preventive	Protects credentials, account information, and transaction data from network interception.
Online Banking	Integrity	Transaction verification	Cryptographic authentication and transaction controls	TLS, OTP/MFA, digital signatures where applicable	Preventive / Detective	Helps ensure transactions are authorized and reduces unauthorized modification or fraudulent transactions.
Online Banking	Availability	Redundant infrastructure and disaster recovery	Replication, failover, backups	Backup/DR systems	Recovery	Allows banking services and data to be restored after

						outages or cyberattacks.
WhatsApp	Confidentiality	End-to-End Encryption	Cryptographic encryption	Signal Protocol	Preventive	Prevents unauthorized parties from reading message contents during communication.
WhatsApp	Integrity	Message authentication	Cryptographic authentication	Signal Protocol	Preventive	Helps detect unauthorized modification of encrypted messages.
WhatsApp	Availability	Infrastructure redundancy	Distributed servers and service redundancy	Cloud/distributed infrastructure	Preventive / Recovery	Helps maintain messaging services when individual systems fail or experience attacks.
Amazon / E-commerce	Confidentiality	Encryption	Secure communication	HTTPS / TLS	Preventive	Protects customer credentials, payment-related information, and personal data during transmission.
Amazon / E-commerce	Integrity	Transaction validation	Cryptographic integrity checks and authentication	TLS, digital signatures where applicable	Preventive / Detective	Helps ensure information is not altered during transmission and supports trustworthy transactions.
Amazon / E-commerce	Availability	Redundancy and DDoS	Traffic filtering and distributed	AWS infrastructure /	Preventive / Recovery	Helps protect services against

		protection	infrastructure	DDoS protection technologies		denial-of-service attacks and infrastructure failures.
Google Drive	Confidentiality	Access control + encryption	Encryption and permission management	TLS, AES, OAuth 2.0, IAM/ACLs	Preventive	Prevents unauthorized users from accessing files and protects data during transmission and storage.
Google Drive	Integrity	Version history and access controls	File versioning and audit mechanisms	Version History, logging	Detective / Recovery	Helps identify unauthorized changes and allows users to restore previous versions of files.
Google Drive	Availability	Data replication and recovery	Redundancy, backups, replication	Cloud infrastructure	Preventive / Recovery	Keeps files accessible and helps recover data after failures or security incidents.

Prevention, Detection and Recovery

Security Function	**Examples of Controls**	**Mechanisms / Technologies**	**Purpose**
Prevention	Encryption	TLS, AES, Signal Protocol	Prevents unauthorized access to data.
Prevention	Authentication	Passwords, MFA, OAuth 2.0	Prevents unauthorized users from accessing accounts.
Prevention	Authorization	IAM, ACLs	Restricts users to permitted resources and operations.
Prevention	Email security	SPF, DKIM, DMARC	Reduces spoofing and impersonation attacks.

Prevention	Access control	Role-based permissions	Limits what authenticated users can do.
Detection	Security logs	Audit logs, SIEM	Records suspicious activities and helps identify attacks.
Detection	Email authentication	DMARC reporting	Helps detect unauthorized email activity and domain spoofing.
Detection	File/version monitoring	Version history and audit trails	Helps identify unauthorized modifications.
Detection	Network monitoring	IDS/IPS and traffic analysis	Detects suspicious or malicious network activity.
Recovery	Backups	Encrypted/cloud backups	Allows lost or corrupted data to be restored.
Recovery	Redundancy	Replication and failover	Maintains service availability when systems fail.
Recovery	Disaster recovery	DR plans and recovery systems	Restores services after major failures or cyberattacks.